

基于五篇论文的智能体安全攻防总结报告

从提示注入、间接提示注入到具备工具与推理轨迹的 LLM 智能体攻防

报告日期：2026-06-20。报告基于本地已处理的 5 篇论文，并附加联网检索得到的近期技术动态与参考文献。

执行摘要

这 5 篇论文构成一条更完整的智能体安全演进线：Tensor Trust 把直接提示注入攻防数据化；StruQ 试图从输入协议和模型训练层面分离指令与数据；AgentDojo 把评估对象推进到真实工具型 agent 的动态任务环境；MELON 在 AgentDojo 上提出运行时重执行防御；UDora 则说明先进 agent 的推理轨迹本身也会成为攻击面。
[P1][P2][P5][P3][P4]

核心判断是：智能体安全的矛盾不再只是“模型会不会输出不当文本”，而是“模型是否会在不可信数据影响下调用工具、泄露数据、改变计划或执行副作用动作”。因此，单靠提示词、单次分类器或离线红队都不够，需要输入通道隔离、工具权限最小化、运行时轨迹监控、动态基准和持续红队共同构成防线。
[P2][P5][P3][P4][W2][W3][W10]

结论	对应证据
提示注入已经从直接聊天攻击发展为 agent 系统级攻击。	Tensor Trust 的 hijacking/extraction 基准 [P1]；Greshake 等人的间接提示注入 [W1]；AgentDojo 的动态工具型 agent 基准 [P5]；InjecAgent [W5]。
防御重点从“识别坏文本”转向“维护任务边界和工具边界”。	StruQ 的结构化查询 [P2]；MELON 的重执行与工具动作比较 [P3]；Task Shield 与设计模式工作 [W7][W14]。
推理链、记忆库和外部数据源都是新的攻击面。	UDora 的推理劫持 [P4]；AgentPoison 的记忆/知识库投毒 [W8]；CausalArmor 的推理遮蔽 [W13]。

0. 本地论文范围和引用方式

正文中的 [P1]-[P5] 指本地 5 篇论文；[W1]-[W14] 指联网补充资料。每个技术判断后都尽量标注来源，方便回到相应论文定位。

编号	论文	本地文件	与本报告的关系
P1	Tensor Trust: Interpretable Prompt Injection Attacks from an Online Game	2311.01011v1.pdf	在线游戏采集 126k+ 攻击和 46k+ 防御；提出 prompt hijacking 与 prompt extraction 双基准；分析 16 类人类攻击策略。
P2	StruQ: Defending Against Prompt Injection with Structured Queries	2402.06363v2.pdf	把开发者指令与用户数据分为结构化双通道；用结构化指令微调让模型忽略 data 通道中的恶意指令；评估手工攻击、TAP、GCG。
P3	MELON: Provable Defense Against Indirect Prompt Injection Attacks in AI Agents	2502.05174v4.pdf	通过遮蔽用户提示并重执行 agent 轨迹，比较工具动作相似度来检测 IPI；在 AgentDojo 上报告 UA、BU、ASR。
P4	UDora: A Unified Red Teaming Framework against LLM Agents by Dynamically Hijacking Their Own Reasoning	2503.01908v3.pdf	动态生成 agent 推理轨迹，寻找扰动插入点，诱导恶意工具调用或目标行为；在 InjecAgent、WebShop、AgentHarm 上评估 ASR。
P5	AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents	2406.13352v3.pdf	动态工具型 agent 安全基准：70 个工具、97 个真实用户任务、27 个注入目标和 629 个安全测试用例；同时评估效用、安全和攻防适应性。

1. 历史背景：从提示注入到智能体攻防

最早的提示注入问题，本质是 LLM 缺乏可靠的“指令/数据”隔离：同一上下文里既有开发者意图，也有用户或第三方文本，模型会把后者误当成可遵循的指令。[P2] Tensor Trust 把这个问题游戏化和数据化：防御者写 prompt 让模型只在访问码正确时输出 access granted，攻击者则试图通过 prompt hijacking 或 prompt extraction 绕过防御。[P1]

随后，风险从“用户直接输入恶意 prompt”扩展为“外部数据源携带恶意指令”。Greshake 等人把这种场景称为间接提示注入，即攻击者不直接对话，而是在网页、邮件、检索内容中埋入指令，让 LLM 应用在读取外部内容时被远程操纵。[W1] AgentDojo 将这类风险建模为工具型 agent 在不可信数据环境中执行真实任务，并用 utility/security 函数同时衡量任务完成和攻击成功。[P5]

进入 agent 阶段后，攻击结果从“文本回答不对”升级为“工具调用不对”。MELON 的 threat model 关注 agent 从工具返回信息中读到恶意任务后执行未授权动作；UDora 又展示了更进一步的攻击面：如果 agent 会规划、推理和分步调用工具，攻击者可以劫持其推理过程，诱导它调用指定恶意工具或执行指定目标行为。[P3][P4] 这也是 OWASP 2025 把 Prompt Injection、Excessive Agency、Sensitive Information Disclosure 等风险同时纳入 LLM 应用安全框架的原因。[W2]

2. 目前的发展阶段

阶段	核心问题	代表论文/方案	阶段特征
直接提示注入阶段	攻击者直接给模型输入恶意指令，诱导越权输出、泄露 prompt 或改写任务。	Tensor Trust [P1]	主要评估 prompt hijacking、prompt extraction、攻击策略聚类和模型鲁棒性。
通道隔离阶段	模型无法区分可信指令和不可信数据。	StruQ [P2]	通过安全前端和结构化指令微调，把 prompt 和 data 变为两个通道。
工具型 agent 阶段	外部工具返回的不可信内容改变 agent 下一步工具动作。	AgentDojo [P5]、MELON [P3]、InjecAgent [W5]	从输出文本安全转为轨迹、工具调用、效用和攻击成功率的联合评估。
推理轨迹攻击阶段	攻击者利用 agent 自身的 planning/reasoning 过程作为可操纵对象。	UDora [P4]	动态找到推理插入点，使恶意行为看起来像 agent 自己推导出的计划。
系统化基准和生产防护阶段	静态 benchmark 和单点防御不足以覆盖真实开放环境。	AgentDojo [P5]、ASB [W6]、AgentDyn [W12]、OpenAI Atlas hardening [W10]	强调动态任务、适应性攻击、自动红队、权限最小化和持续修补。

3. 当前存在的关键问题

- 指令和数据缺乏强边界。StruQ 明确指出普通 LLM 会在整段输入中寻找可遵循指令，因此攻击者可以把恶意指令伪装成用户数据。[P2]
- 攻击目标已从“让模型说错话”变成“让系统做错事”。MELON 关注工具动作是否被恶意任务主导，UDora 关注是否诱导指定工具调用，这说明行为安全比文本安全更核心。[P3][P4]
- 安全与效用存在真实张力。AgentDojo 显示当前 LLM 无攻击时也只能完成不到 66% 的任务；MELON 论文中，强检测器可能降低 Utility under Attack；StruQ 虽能压低手工攻击 ASR，但对 GCG 仍不完全免疫。[P5][P2][P3]
- 现有 benchmark 容易静态化。AgentDojo 明确反对固定攻击集合，主张作为可扩展动态环境持续加入新任务、防御和自适应攻击；AgentDyn 进一步指出既有基准存在开放任务不足、第三方有益指令不足和用户任务过简的问题。[P5][W12]
- 推理链和长程记忆扩大了攻击面。UDora 利用 reasoning trace；AgentPoison 利用记忆或知识库投毒，说明 agent 的内部状态和外部长期上下文都需要安全治理。[P4][W8]
- 提示注入更像 confused deputy，而不只是字符串过滤。NCSC 把 LLM 描述为 inherently confusable deputy，意味着不能期待像 SQL 注入那样靠一次性转义彻底解决。[W3]

4. 已有解决方案和技术路线

4.1 数据集、基准和红队路线

Tensor Trust 的贡献是把真实人类提示注入策略规模化采集，并把问题拆成 prompt hijacking 与 prompt extraction；它适合研究攻击策略结构、传播和模型鲁棒性。[P1] AgentDojo 则把评估目标推进到工具调用、动态环境和真实任务复杂度，首版包含 70 个工具、97 个真实任务、27 个注入目标和 629 个安全测试用例。[P5] InjecAgent、ASB 和 AgentDyn 继续扩展这一基准化方向。[W5][W6][W12]

UDora 代表更主动的红队路线：不是等待攻击样本，而是自动构造能劫持推理轨迹的扰动，并在 InjecAgent、WebShop、AgentHarm 等数据集上测量 ASR。[P4] OpenAI 对 Atlas 的 hardening 也体现同一趋势：用强化学习训练自动攻击者，发现长程 agent exploit，再快速更新模型和系统防护。[W10]

4.2 输入协议和模型训练路线

StruQ 是最清晰的“协议优先”方案：前端用特殊格式把 prompt 与 data 分离，模型通过结构化指令微调学习只遵循 prompt 通道。论文报告手工攻击成功率降至 <2%，TAP 在 Llama 上从 97% 降至 9%，GCG 从 97% 降至 58%。[P2] 这说明通道隔离很强，但对自适应/白盒优化攻击仍需配合其他防线。[P2]

4.3 运行时检测和反事实重执行路线

MELON 的关键观察是：成功 IPI 会让 agent 下一步动作更依赖恶意任务而非用户任务。因此它遮蔽用户提示、重执行轨迹，再比较原执行和遮蔽执行中的工具动作。若两者仍相似，则动作可能由工具返回内容中的恶意任务驱动。[P3] 在 AgentDojo 上，MELON/MELON-Aug 取得低 ASR 且保持较高 UA，例如 GPT-4o 上 MELON-Aug 为 68.72% UA、0.32% ASR。[P3]

CausalArmor 是 2026 年同一思路的推进：它用因果消融估计不可信片段是否支配决策，并在必要时做定向 sanitization 和 chain-of-thought masking。[W13] 这类方法的共同优点是贴近 agent 决策过程，缺点是增加运行时成本，并需要定义“相似动作”“支配性片段”等判据。[P3][W13]

4.4 任务一致性、工具权限和系统设计路线

Task Shield 把防御目标表述为 task alignment：候选工具调用必须与用户任务一致，而不是只判断输入中有没有坏词。[W7] OpenAI 和设计模式论文则更强调系统架构：限制 agent 可见数据、缩小工具权限、把高风险动作放到显式确认或专用接口后面，并把 untrusted content 当作低权限数据处理。[W11][W14]

这一路线与 StruQ 的原则一致：安全边界应由系统和协议承载，而不是让同一个自由文本上下文同时承载系统指令、用户数据、网页数据和工具输出。[P2][W14]

4.5 记忆、RAG 和长期状态防护路线

AgentPoison 表明，攻击者可以污染 agent 的记忆或知识库，使未来任务被劫持。[W8] 这把威胁从“当前上下文”扩展到“长期状态”，与 Tensor Trust 的一次性 prompt 攻防不同，也比 MELON 的单轨迹检测更难，因为恶意触发可能延迟发生。[P1][P3][W8]

5. 关键指标如何解读

指标	含义	适用论文	注意事项
ASR	Attack Success Rate，攻击成功率，越低越好。	AgentDojo、StruQ、MELON、UDora [P5][P2][P3][P4]	不同 benchmark 的 ASR 不可直接横比，需看任务、工具权限和成功定义。AgentDojo 使用 targeted ASR 衡量攻击者目标是否达成。
UA	Utility under Attack，攻击存在时完成用户任务的能力，越高越好。	AgentDojo、MELON [P5][P3]	纯拒绝可以降低 ASR，但会牺牲 UA；因此 UA/ASR 要一起看。
BU	Benign Utility，无攻击时效用。	AgentDojo、MELON [P5][P3]	防御不能只在攻击场景有效，还要保留日常任务能力。
HRR / extraction robustness	提示劫持/提示提取鲁棒性。	Tensor Trust [P1]	更接近 prompt 级别，不完全等价于工具型 agent 行为安全。
AlpacaEval win rate	正常文本任务质量。	StruQ [P2]	衡量通道隔离和微调是否伤害通用效用。

6. 对后续学习和工程落地的建议

- 1 先读 Tensor Trust 和 Greshake 等人的 IPI 论文，建立“指令/数据混淆”的基本攻击模型。[P1][W1]
- 2 再读 StruQ，理解为什么 prompt/data 分离应成为协议层设计，而不是纯提示工程。[P2]

- 3 读 AgentDojo、InjecAgent、MELON，掌握工具型 agent 的评估维度：任务完成、攻击成功、工具动作、误报漏报。[P5][P3][W5]
- 4 读 UDora 和 AgentPoison，补上推理轨迹攻击与长期记忆攻击两个前沿攻击面。[P4][W8]
- 5 最后读 OWASP、NCSC、OpenAI 和设计模式论文，把研究结论转成工程约束：最小权限、可信/不可信通道隔离、风险动作确认、动态红队和持续监控。[W2][W3][W10][W11][W14]

附录 A：联网检索到的最新动态与有影响力论文

以下资料按 2026-06-20 的联网检索结果整理，优先采用 arXiv、会议论文、官方组织页面和 OpenAI/NCSC/OWASP 等一手来源。

编号	资料	年份	为什么值得看	链接
W1	Greshake et al., Not what you've signed up for	2023	间接提示注入早期系统化论文：外部网页、邮件、检索数据可远程影响 LLM 应用，造成数据窃取、传播污染和 API 调用操纵。	https://arxiv.org/abs/2302.12173
W2	OWASP Top 10 for LLM Applications 2025	2025	将 Prompt Injection 列为 LLM01，并同时强调训练数据投毒、供应链、过度代理、敏感信息泄露等生产风险。	https://owasp.org/www-project-top-10-for-large-language-model-applications/
W3	NCSC, Prompt injection is not SQL injection	2025	把 LLM 视为 inherently confusable deputy，建议把目标从“彻底修复”转为降低风险与影响。	https://www.ncsc.gov.uk/blog-post/prompt-injection-is-not-sql-injection
W4	AgentDojo	2024	动态 agent 安全环境：97 个现实任务、629 个安全测试用例，用于评估工具返回不可信数据导致的 IPI。	https://arxiv.org/abs/2406.13352
W5	InjecAgent	2024	工具集成 agent 的 IPI 基准：1,054 个测试用例，覆盖 17 个用户工具和 62 个攻击者工具。	https://arxiv.org/abs/2403.02691
W6	Agent Security Bench	2024	统一形式化 agent 攻防：10 场景、400+ 工具、23 类攻防方法、近 90,000 测试用例，最高平均 ASR 84.30%。	https://arxiv.org/abs/2410.02644
W7	Task Shield	2024/2025	以 task alignment 为核心的 IPI 防御：检查候选工具行为是否与用户任务一致。	https://arxiv.org/abs/2412.16682
W8	AgentPoison	2024	红队测试长期记忆与知识库：通过污染记忆/RAG 让 agent 在未来任务中被劫持。	https://arxiv.org/abs/2407.12784
W9	PromptArmor	2025	用现代 LLM 做注入检测与移除的轻量 guardrail，被作者建议作为 prompt injection defense baseline。	https://arxiv.org/abs/2507.15219
W10	OpenAI, hardening ChatGPT Atlas	2025	用强化学习自动红队发现浏览器 agent 中长程提示注入攻击，并通过对抗训练和系统级防护快速响应。	https://openai.com/index/hardening-atlas-against-prompt-injection/
W11	OpenAI, Designing AI agents to resist prompt injection	2026	从产品架构角度讨论如何降低 agent 遭提示注入操纵的风险。	https://openai.com/index/designing-agents-to-resist-prompt-injection/
W12	AgentDyn	2026	动态开放式 benchmark：60 个开放任务、560 个注入测试，突出已有基准过于静态和任务过于简单的问题。	https://arxiv.org/html/2602.03117v3
W13	CausalArmor	2026	基于因果归因的 IPI guardrail：检测不可信片段是否支配决策，并做定向清洗和推理遮蔽。	https://arxiv.org/html/2602.07918v1
W14	Design Patterns for Securing LLM Agents against Prompt Injections	2025	提出具有可证明抗提示注入性质的 agent 设计模式，并讨论效用和安全权衡。	https://arxiv.org/html/2506.08837v3

附录 B：一张攻防路线图

层次	攻击面	典型攻击	防御抓手	来源
输入层	用户 prompt、网页、邮件、检索结果	直接/间接提示注入、prompt extraction	结构化查询、数据通道隔离、输入清洗	[P1][P2][W1]
规划层	reasoning trace、计划步骤	推理劫持、恶意中间目标注入	推理遮蔽、反事实重执行、审计轨迹	[P3][P4][W13]
工具层	API、浏览器、邮箱、数据库、支付等	恶意工具调用、数据外泄、越权副作用	最小权限、任务一致性检查、风险动作确认	[P5][P3][W7][W11]
记忆层	长期记忆、知识库、RAG 索引	记忆投毒、延迟触发、知识库污染	来源认证、检索结果隔离、记忆写入审批	[W8]
评估层	静态测试集和红队流程	对静态 benchmark 过拟合、自适应攻击绕过	动态环境、开放任务、自动红队、持续响应	[P5][P4][W10][W12]

附录 C：本报告的边界

本报告不是对全部 agent security 文献的系统综述，而是以用户文件夹中的 5 篇正确论文为主轴，再补充近期公开资料。联网资料侧重 prompt injection 与 agent 工具调用安全，未全面覆盖模型权重攻击、训练供应链、模型窃取、隐私合规和传统软件漏洞。